

the infrastructure. Device evasion is a highly technical and systematic approach to penetrating a network.

Router evasion

Often, routers are the first devices accessible from outside a firm's network. Routers maintain their own routing tables, which store the paths to destination IP ranges, with a cost metric. The routing table is checked every time a TCP/IP packet is processed prior to being sent to the desired destination. Besides this, routers implement intelligent algorithms to speed up the routing process. The router device thus acts as a first line of defence from the cybersecurity perimeter standpoint. In earlier articles in this series, we learnt about denial of service (DoS) attacks, IP spoofing attacks, man-in-the-middle attacks and packet-crafting attacks. All these attack vectors can either fool a router into routing malicious packets into the target network, or can simply render it functionally useless, thus disrupting the whole network. Besides this, there are a few router-specific techniques too, which are mentioned below.

Route hijacking: In this method, the attacker first sniffs the traffic originating from a router. Based on the information gathered, the router is then supplied with bogus source and destination IP addresses, which are spoofed purposely to trick the router. As the router tracks these and updates its routing table, this process can become very overwhelming to the router, causing its routing table to overflow and get corrupted. This is similar to a DoS attack, but can take much less time, in practice. An expert attacker can further exploit this situation by feeding the vulnerable router with its own IP segment, and waiting for the routing table to get built up again. The very first routing protocol, called RIP, didn't have a built-in authentication mechanism to verify the authenticity of the routes being updated. Hence, a forged RIP packet can easily disrupt the routing table, and this scenario becomes seriously dangerous if multiple routers are connected together using the RIP protocol. Modern routers usually don't fall prey to this attack; however, an improperly configured router can still be vulnerable.

IOS penetration: Like any other network device, a router runs its own operating system, which can be vulnerable to attacks. For example, most wireless routers and early-generation industry-grade routers were running on a compromised kernel OS. Attackers with a thorough knowledge of such vulnerabilities can write scripts and programmatically subject the device to DoS or other dangerous attacks, such as remote code execution. Once the OS has been penetrated, attackers can remotely run commands to change critical configurations and settings. Attackers can route traffic to malicious servers to steal and corrupt data, and cause even more damage.

Firewall evasion

It is a common practice to host a firewall behind a router; however, many mid-sized firms running only one office

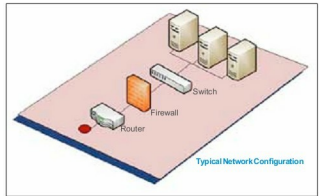


Figure 1: Typical network configuration

may completely remove the router, turning the firewall into the first line of defence. As compared to the router, a firewall acts as a strong opposition to attacks because its kernel functionality is designed for this, causing serious challenges to attackers wanting to get past a well-configured firewall.

As we know, a firewall is a rule-based device that allows or disallows traffic entering or exiting a security perimeter. When a source address initiates a connection with a host behind a firewall, the firewall rules intercept the connection, interpret it and take appropriate action. This also tells us that the TCP handshake actually happened between the source and firewall. In case the connection being established is not allowed, based on the rules configured, the firewall drops the connection by sending a TCP RST signal to the source. If the connection is allowed, it initiates a connection with the destination and performs the packet transfer. This also shows us that the source and destination IP addresses, as well as the ports, are very important from the firewall's standpoint. With this fundamental theory in mind, let's look at few firewall-specific evasion attacks.

Firewall request spoofing: If the attackers can spoof their packets to make them look like they are coming from the internal network segment of the firewall, an improperly configured firewall may allow those through the system. Similar effects can be achieved by spoofing the MAC address, in case the firewall is keeping a track of all internal MAC addresses.

Firewall DoS: Modern firewalls intercept each packet and apply more intelligent checks on them than their predecessors, before letting them through to the network. Typical checks by anti-virus and anti-spyware algorithms, attack anomalies, etc, are performed on each packet. This feature, though tremendously useful, is exploited by attackers in some cases. Apart from sending an overwhelming number of requests, there are a few other tricks used by attackers. In one case, a malicious request to a known destination host listening on a known port is sent multiple times, but with the source IP and port of that packet spoofed to a non-existent host. There is no way for the firewall to know this, and hence this results